

Root compromise of a shared hosting server via an outdated WordPress plugin

Server **panel2.firevps.net** (51.79.149.130) — CyberPanel / OpenLiteSpeed, 81 configured websites (51 primary + child domains)

DATE PREPARED	PREPARED BY	STATUS	
14 Jul 2026	ServerAlly (AI-assisted)	Contained · cleaned in place	 CRITICAL

01 Executive summary

An attacker gained **full administrator (root) control** of the server **panel2.firevps.net** and held it for roughly two months. They got in through an **outdated, vulnerable WordPress plugin** on one hosted website, planted hidden backdoor files, escalated to root, and installed a stealth backdoor that quietly phoned out to an attacker-controlled system so they could return at any time.

The active backdoor and the known malicious files have now been **removed and the server contained**. Because a root-level compromise exposes everything on the machine, the remaining work is a full credential reset and the rebuild of the worst-affected site. This report documents how it happened, what was affected, what has been fixed, and what management must still authorise.

02 Key facts

AFFECTED SERVER panel2.firevps.net 51.79.149.130 · Ubuntu · CyberPanel / OpenLiteSpeed	WEBSITES CONFIGURED 81 51 primary + 23 child domains assessed · 7 suspended (no files)
ENTRY POINT Vulnerable WordPress plugin wp-file-manager on richhome.com.bd	ATTACKER ACCESS WINDOW ~2 months (root) Backdoor active since 21 May 2026
FIRST KNOWN FOOTHOLD October 2022 richhome.com.bd (based on file timestamps)	SEVERITY Critical Full root takeover of a multi-tenant server

03 How the attacker got in

One of the hosted websites, **richhome.com.bd** (WordPress), was running the **wp-file-manager** plugin — a plugin with a well-documented history of critical security holes that let a stranger upload files to the server *without logging in*.

The server's own web-access logs show **automated attack scanners** repeatedly probing for two classic, widely-exploited weaknesses:

EXPLOIT SIGNATURES OBSERVED IN THE LOGS

WEAKNESS (CVE)	WHAT IT LETS AN ATTACKER DO
CVE-2017-9841 — PHPUnit eval-stdin.php	Run arbitrary code on the server if a vulnerable component is web-reachable.
CVE-2018-9206 — jQuery-File-Upload	Upload arbitrary files (a "webshell") to the server.

Once a file could be uploaded, the attacker planted a **webshell** — a small hidden file that runs any command through the browser — and used that foothold to escalate to **root** (full server control). richhome.com.bd appears to have been compromised since **October 2022**, making it a long-standing entry point that was never fully cleaned.

04 Timeline of the attack

October 2022

First webshell planted on richhome.com.bd — the site is quietly compromised and stays that way for years.

2023 – 2025

More webshells added over time (disguised as normal pages: `product.php`, `goods.php`, and others).

19 May 2026

A fresh upload webshell (`fcefabhjea.php`) is dropped into the site's uploads folder.

21 May 2026

Root escalation. The attacker installs a stealth *gsocket* backdoor named `initfs`, disguised as a system service and phoning out on port 443 (to slip past the firewall) to an attacker system.

10 Jul 2026, 20:05

An automated tool copies the same webshell into **8 folders in 7 seconds** — planting redundant backdoors for resilience.

14 Jul 2026

Detected, contained & cleaned by ServerAlly — backdoor removed, malicious files quarantined, all 51 sites swept.

05 Scope & impact

Because the attacker held **root**, every website and all data on the server were exposed for the duration of the compromise (~2 months). The full hosting footprint was assessed — **51 primary sites and 23 child / sub-domains** were scanned for malware; 7 suspended sites have no files on disk. Confirmed malware was found only within **three accounts** (below); every other site is clean.

WEBSITE	PANEL ACCOUNT	WHAT WAS FOUND	STATE
desktopit.net (+ child domains)	deskt7376	Backdoor traces, a fake-cron C2 beacon, and 22 webshells in a child domain (old.rmp.gov.bd). Its ~10 other child domains were swept — clean.	Cleaned
richhome.com.bd	richh9509	Long-standing infection (2022+): many webshells, 3 fake admin accounts, hidden index.php shells, plus loose shells in the plugin folder	Needs rebuild
nwdcr.edu.bd	nwdcr9384	A webshell (goods.php) and a Python C2 beacon	Cleaned
All other sites	—	48 primary sites + 22 child / sub-domains swept (7 suspended have no files on disk) — no malware found	Verified clean

06 Remediation completed

- ✓ **Root backdoor removed.** The `initfs` process was killed, its auto-start service disabled and masked, and its files moved to a quarantine folder. Evidence was preserved for investigation.
- ✓ **Command-and-control blocked.** The attacker's callback address (152.53.173.29) was blocked in the server firewall (CSF).
- ✓ **Site malware quarantined.** Webshells on desktopit.net, richhome.com.bd and nwdcr.edu.bd were moved to quarantine (not deleted — preserved as evidence).
- ✓ **Fake admin accounts removed** from richhome.com.bd (3 unauthorised WordPress administrators).
- ✓ **Whole-server sweep.** All 51 sites checked for webshells; only `root` holds super-user rights; no crypto-miner, no kernel/loader hooks, and no second implant were found.

07 Outstanding actions — management authorisation required

- ❑ **Rotate ALL credentials, from a clean device.** Root password, all 51 CyberPanel account passwords, SSH keys, and every database and WordPress admin password. A root compromise means every secret on the box must be treated as stolen.
- ❑ **Review the 4 root SSH keys** and remove any that are not recognised (they currently look like legitimate CI/deploy keys, but must be confirmed).
- ❑ **Rebuild richhome.com.bd from clean.** It has been compromised since 2022 and keeps revealing more malware; a fresh WordPress core + fresh plugins/theme with clean content is safer than continued cleanup. Its last 5 plugin-folder shells were quarantined on 14 Jul — including a hidden-admin backdoor that recreates the rogue WordPress user `david.pueray`. That database account must be deleted (the rebuild handles it).
- ❑ **Patch or remove wp-file-manager** and audit every site for outdated, exploitable plugins to close the entry point.
- ❑ **Consider a full server rebuild.** See the assessment below.

! **Honest assessment.** A server that has been compromised at the root level can never be proven 100% clean by cleanup alone — the only fully certain remediation is a **rebuild from a fresh operating system** with data restored from a known-good backup. The box is currently **cleaned in place** per the owner's decision; if it holds sensitive data, a rebuild is strongly recommended. Ongoing monitoring should remain enabled.

08 Technical appendix — indicators of compromise

ROOT BACKDOOR

TYPE	gsocket / gs-netcat reverse-shell backdoor (root)
BINARY	/usr/sbin/initfs (ran as /sbin/initfs)
SHA-256	5bb332ff977919ccbab39a2b4ac91261c8f316628044c7473369d91cc78ade65
PERSISTENCE	/lib/systemd/system/initfs.service – description faked as "D-Bus System Connection Bus"
C2 ADDRESS	152.53.173.29 : 443 (outbound; spoofed reverse-DNS "cdnjs.cloudflare.com")
ACTIVE SINCE	21 May 2026 (file timestamps backdated to 2015 to hide)

WEBSHELL FAMILIES OBSERVED

DISGUISED	Password-protected shells hidden as index.php in plugin/theme folders (markers: secretyt / pwdyt)
FILE MANAGER	"PHP File Manager v1.4" backdoor (built-in login admin / phpfm) as wp-blog.php
COMMAND SHELL	Obfuscated eval(\$_POST["command"]) shells (e.g. ftde.php, wp-head.php)
DROPPED FILES	.phar and image-disguised (.jpg/.png) PHP payloads in upload/asset folders

ENTRY-POINT VULNERABILITIES

CVE-2017-9841	PHPUnit eval-stdin.php remote code execution (probed in access logs)
CVE-2018-9206	jQuery-File-Upload arbitrary file upload (probed in access logs)
PLUGIN	wp-file-manager on richhome.com.bd (history of critical RCE flaws)

i Not on the server: desktopit.net's public pages briefly showed casino spam. This was traced to a **DNS / Cloudflare cache** layer, **not** to files on panel2 — it is a separate issue to clear at the DNS level.

